

Desafio Prático Integrador — Mini-CTF Defensivo Linux

Cenário

O servidor Ubuntu da empresa fictícia "**Linux Agency**" apresenta indícios de atividade suspeita e configurações severamente inseguras. A sua missão é auditar, conter os danos, aplicar as correções e documentar toda a intervenção — como se fosse chamado a responder a um incidente real.

Ambiente Virtual

- TryHackMe — Linux Agency (gratuito): <https://tryhackme.com/room/linuxagency>

Metodologia de Resposta (Roteiro de Ações Exigidas)

Fase 1 — Identificação e Triagem

Análise de Rede e Portas: identificar quais os portos e serviços ativos que estão expostos desnecessariamente.

ss -tuln

```
root@ip-10-129-162-185:~# ss -tuln
```

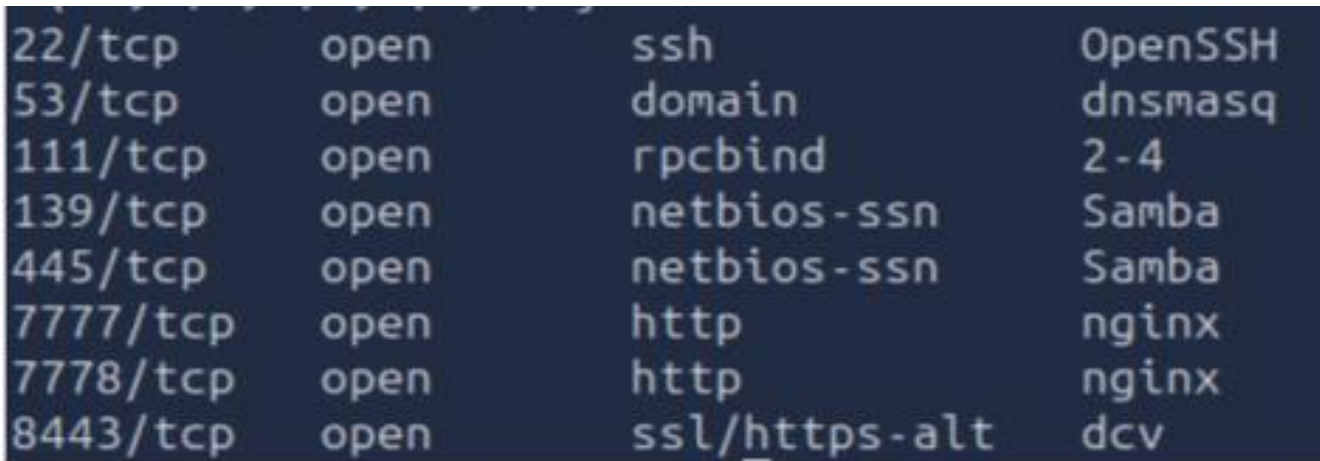
NetId	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	0.0.0.0:53	0.0.0.0:*	
udp	UNCONN	0	0	10.129.162.185:568	0.0.0.0:*	
udp	UNCONN	0	0	127.0.0.1:111	0.0.0.0:*	
udp	UNCONN	0	0	172.17.255.255:137	0.0.0.0:*	
udp	UNCONN	0	0	172.17.0.1:137	0.0.0.0:*	
udp	UNCONN	0	0	10.129.191.255:137	0.0.0.0:*	
udp	UNCONN	0	0	10.129.162.185:137	0.0.0.0:*	
udp	UNCONN	0	0	0.0.0.0:137	0.0.0.0:*	
udp	UNCONN	0	0	172.17.255.255:138	0.0.0.0:*	
udp	UNCONN	0	0	172.17.0.1:138	0.0.0.0:*	
udp	UNCONN	0	0	10.129.191.255:138	0.0.0.0:*	
udp	UNCONN	0	0	10.129.162.185:138	0.0.0.0:*	
udp	UNCONN	0	0	0.0.0.0:138	0.0.0.0:*	
udp	UNCONN	0	0	0.0.0.0:8443	0.0.0.0:*	
udp	UNCONN	0	0	127.0.0.1:323	0.0.0.0:*	
udp	UNCONN	0	0	:::53	:::*	
udp	UNCONN	0	0	:::1:111	:::*	
udp	UNCONN	0	0	:::8443	:::*	
udp	UNCONN	0	0	:::1:323	:::*	
tcp	LISTEN	0	32	0.0.0.0:53	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:22	0.0.0.0:*	
tcp	LISTEN	0	50	0.0.0.0:139	0.0.0.0:*	
tcp	LISTEN	0	10	0.0.0.0:8443	0.0.0.0:*	
tcp	LISTEN	0	50	0.0.0.0:445	0.0.0.0:*	
tcp	LISTEN	0	200	127.0.0.1:5433	0.0.0.0:*	
tcp	LISTEN	0	1024	127.0.0.1:20640	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:111	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:7778	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:7777	0.0.0.0:*	
tcp	LISTEN	0	32	:::53	:::*	
tcp	LISTEN	0	4096	:::22	:::*	
tcp	LISTEN	0	50	:::139	:::*	
tcp	LISTEN	0	10	:::8443	:::*	
tcp	LISTEN	0	50	:::445	:::*	
tcp	LISTEN	0	4096	:::7778	:::*	
tcp	LISTEN	0	4096	:::7777	:::*	
tcp	LISTEN	0	4096	:::1:111	:::*	

Análise dos Principais Resultados do comando ss -tln

Porta	Protocolo	Endereço Local	Serviço Provável	Nível de Risco	Descrição da Vulnerabilidade / Exposição
53	UDP/TCP	0.0.0.0 / [::]	DNS (Domain Name System)	Médio	Serviço DNS exposto publicamente; pode ser usado para amplificação de DDoS se aberto para redes externas.
22	TCP	0.0.0.0 / [::]	SSH (Secure Shell)	Baixo	Acesso remoto SSH exposto em todas as interfaces. Recomenda-se uso de chaves SSH e restrição por firewall/fail2ban.
139	TCP	0.0.0.0 / [::]	NetBIOS Session Service	Alto	Protocolo legado vulnerável a enumeração de usuários e ataques de relay (SMB/NetBIOS).
445	TCP	0.0.0.0 / [::]	Microsoft-DS (SMB)	Crítico	Serviço SMB exposto na rede. Historicamente associado a graves vulnerabilidades de execução de código remoto (EternalBlue, etc.).
111	UDP/TCP	127.0.0.1 / [::1] (Local)	RPCbind / rpcbind	Baixo	Vinculado apenas ao localhost, baixo risco de exposição externa direta.
137	UDP	Múltiplos (0.0.0.0 / 172.x / 10.x)	NetBIOS Name Service	Alto	Serviço de resolução de nomes NetBIOS exposto em várias interfaces de rede, permitindo vazamento de informações.
138	UDP	Múltiplos (0.0.0.0 / 172.x / 10.x)	NetBIOS Datagram Service	Alto	Tráfego NetBIOS Datagram aberto em interfaces de rede, permitindo spoofing e enumeração.
323	UDP	127.0.0.1 / [::1]	Chrony (NTP)	Baixo	Serviço de sincronização de hora interno (localhost).
8443	UDP/TCP	0.0.0.0 / [::]	HTTPS Alternativo / Proxy / WebApp	Médio	Serviço HTTPS alternativo aberto para todas as interfaces. Necessário auditar a aplicação rodando nesta porta.
5433	TCP	127.0.0.1	PostgreSQL (Alt)	Baixo	Banco de dados restrito ao localhost.
20640	TCP	127.0.0.1	Serviço Interno / Daemon	Baixo	Porta efêmera/interna vinculada exclusivamente ao localhost.
7777	TCP	0.0.0.0 / [::]	Aplicação Customizada / Gestão	Médio	Porta não padronizada aberta em todas as interfaces. Risco de exposição de painéis de administração ou backdoors.
7778	TCP	0.0.0.0 / [::]	Aplicação Customizada / Gestão	Médio	Porta adicional aberta em todas as interfaces, associada à porta 7777.

Recomendações de Segurança

Categoria	Ação Recomendada	Impacto
Serviços SMB/NetBIOS (445, 139, 137, 138)	Desativar o protocolo NetBIOS e restringir o acesso ao SMB (porta 445) apenas para redes confiáveis via firewall (UFW/iptables), ou desativar o serviço se não for necessário.	Elimina vetores de ataques de ransomware, enumeração e execução remota.
Exposição de Portas Customizadas (7777, 7778)	Verificar quais aplicações estão rodando nestas portas. Se forem serviços internos, restringir o acesso para 127.0.0.1 ou utilizar VPN/Tunnel para acesso externo.	Reduz a superfície de ataque para aplicações desconhecidas ou não auditadas.
Serviço DNS (Porta 53)	Garantir que o servidor DNS (como BIND ou systemd-resolved) não responda a consultas recursivas públicas para evitar ataques de amplificação DDoS.	Protege contra uso indevido da infraestrutura em ataques de negação de serviço.
Hardening de SSH (Porta 22)	Desativar autenticação por senha, permitir apenas chaves SSH, alterar a porta padrão se viável, e configurar o Fail2ban contra ataques de força bruta.	Aumenta significativamente a segurança contra invasões via força bruta.
Auditoria Geral de Firewall	Implementar uma política restritiva de firewall (ex: UFW default deny incoming), libertando apenas os serviços essenciais para endereços IP autorizados.	Garante o princípio do menor privilégio na rede.

nmap -sV localhost

22/tcp	open	ssh	OpenSSH
53/tcp	open	domain	dnsmasq
111/tcp	open	rpcbind	2-4
139/tcp	open	netbios-ssn	Samba
445/tcp	open	netbios-ssn	Samba
7777/tcp	open	http	nginx
7778/tcp	open	http	nginx
8443/tcp	open	ssl/https-alt	dcv

ANÁLISE DETALHADA DAS PORTAS E SERVIÇOS EXPOSTOS**- Porta 22/tcp (OpenSSH):**

Serviço: OpenSSH

Risco Potencial: Exposição direta do serviço SSH na rede. Se o acesso estiver configurado com autenticação por senha padrão ou se a versão estiver desatualizada.

-Porta 53/tcp (dnsmasq):

Serviço: dnsmasq (DNS)

Risco Potencial: O dnsmasq exposto na porta TCP pode indicar um serviço de resolução ou cache DNS mal configurado.

- Porta 111/tcp (rpcbind 2-4):

Serviço: rpcbind (SUNRPC)

Risco Potencial: O rpcbind gerencia serviços RPC (Remote Procedure Call).

- Portas 139/tcp e 445/tcp (Samba / NetBIOS & SMB):

Serviço: Samba (SMB)

Risco Potencial: Altamente crítico se exposto diretamente. O protocolo SMB é alvo histórico de vulnerabilidades graves (como EternalBlue / CVE-2017-0144).

- Portas 7777/tcp e 7778/tcp (nginx):

Serviço: nginx (Servidor Web)

Risco Potencial: Múltiplas instâncias ou portas web não padrão expostas. Podem hospedar aplicações web vulneráveis.

- Porta 8443/tcp (dcv):

Serviço: NICE DCV (Remote Desktop / Streaming de Área de Trabalho)

Risco Potencial: Solução de acesso remoto gráfico. Caso utilize certificados autoassinados, senhas fracas ou possua vulnerabilidades na versão do DCV.

Auditoria de Contas: procurar por utilizadores com permissões excessivas, contas sem palavra-passe associada ou chaves públicas suspeitas em `authorized_keys`

```
sudo cat /etc/shadow | awk -F: ' $2==" " {print $1}'
```

Não retornou nenhum resultado, significa que não existem usuários no sistema com a senha vazia, o que é um bom sinal de segurança.

```
cat ~/.ssh/authorized_keys
```

Lista de chaves públicas SSH (no formato ssh-rsa), encontradas dentro do arquivo

```
cat ~/.ssh/authorized_keys
```

```
ubuntu@tryhackme:~$ cat ~/.ssh/authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCMLOt6NhiqH5Rp36qJt4jZwfvb/H/+YLRTx5mS9dSyxump8+chjxkSN0rdgNtZ6XoaDDdik
slQvKMqCqJqHqp4jh9xTQTj29tagUaZmR0gUwateJPG0SfqNvNExgsTtu2DW3SxCQYwrMtu9S4myr+4x+rwQ739SrPLMdBmughB13uC/3DCsE4
aRvWL7p+McehGGkqvyAfhuX/9SNgnIKayozWMPHADhpYLAomGnTtd8Cn+01ILmvqz5kJDYmnLKppKw2mgtAVeejNXGC7TQRkH6athISWzek9P
XiFVu6IZsJePo+y8+n2zh0XM2mHx01Qyvk2WZuQCvLpWk92eF amiOpenVPN

ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCKRBDPIgwF5ZmB7TXfzkL6BD94dEqBYggDlk0Yzr00w22mJgSeGmuvKVTrwOpKsV40MZL0P4
5nfBTnCov8N2shzeEU5LgJ6Psz9IUeU2S+sNxmdn80ooy1BkbfB0DrGwiUqmRMAizZpVPe0dkPHVw+k3ln1zmLg7PeFYmEyeSp00Ufi4wd9iIp
jxc7mmHMj/UhS4Hk0PBL2G4kFwBJMd/oOGRz10EKUXeYQgv+9JqCukXCUNh0GKkbVCWL/nDd3J4FNqPBurAS4AZSqN7n1E/dZEXg2sICKoFc+k
g47SN81Jbjc4ohU7oYrBi6CpynMdMpS4jIWBebU6Arq9Ezbn4b cmnatic

ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQAC200LLVQk4Ydq5xRqgsyQN9u0/r3NQ+cY6Tu0QAQgwUVgg7KpS8xDP3GA0J0hZPUJKY6ZI45
7W/vsIwSk5xikMvsroJDtg7bjZwqjdrjjckeJKtnR2zNwS7i340h+MezN6QqGgMQnQci3N0vMyELDTBQIXUMUF9Rw5wc5euabbfIHxE78+NpAS
sKLakBxCkkwv/N7CGU06BTRwsbXYBeH+JjLaml2a0BbWrHAjawRSiZTFuqY9Zy/x1rY2SDR9ZtqTrIqBbhCOjUthQH+rV1fPN27VIvkBiN94+
Jgl9N6UJ9S9010A9/AkvCcm49EwLR8u9WRkwwwjvZb0MTGzD saqib.shabbir

ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQADv+eTaawXys/ShDXGE/KIeLCUYFqP+QqAwL6LsFm19JR2ka8LwvRM2WQ6QKfLnPw47LDggs
BcdehASvBj4PaI+boh4slv/RbZCJIMTYKXyh+PysjwefcPs6SQ97NCMbXux/jLMxthXhHwBvMi8/jnKFe4725JZbHHSQW2e32taLkxxVWajjQ6
rFXzV3100PycHu1G6BkBasqVXvT0D/L6A3D9DA9H3P2gFN+BoLWJ//Fnnu1fVYQnnLzNsHaCRyHXBdhFf1Ih5uVGoHpLU9YyBag0fu+3UQcTFX
GoInCPlaiXgwtXYGZvyi1BjUrMjmkKLtu2m9F/w0hLrycYTh eu-west-3-vuln-vms
```

Fase 2 — Contenção

Ativar a firewall UFW, bloqueando todas as portas que não sejam estritamente necessárias para o negócio

```
root@ip-10-130-186-64:~# sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
```

O comando executado alterou a política padrão do **UFW (Uncomplicated Firewall)** para o tráfego de entrada (*incoming*) para **negado** (*deny*).

Isso significa que, a partir de agora, **qualquer conexão externa que tente entrar no seu servidor será bloqueada por padrão**, devendo criar regras específicas permitindo portas ou serviços essenciais.

```
ubuntu@tryhackme:~$ sudo ufw allow 22/tcp
Rules updated
Rules updated (v6)
```

```
ubuntu@tryhackme:~$ sudo ufw enable
Firewall is active and enabled on system startup
```

O servidor agora está com o tráfego de entrada bloqueado por padrão, mantendo abertas apenas as portas explicitamente permitidas o SSH na porta 22.

Fase 3 — Enriquecimento / Remediação

- a) Restringir Acesso por Firewall (UFW / iptables): Bloquear o acesso externo às portas sensíveis (445, 139, 137, 111, 53), permitindo-as apenas via VPN ou rede interna confiável.
- b) Desativar Serviços Desnecessários: Desabilitar o suporte a NetBIOS/SMB caso a máquina não pertença a um domínio Windows ou não compartilhe arquivos na rede pública.
- c) Endurecimento do SSH (Hardening): Desativar autenticação por senha no SSH, permitindo apenas chaves públicas, e alterar a porta padrão ou utilizar ferramentas como Fail2ban.
- d) Auditoria de Aplicações: Verificar quais serviços estão associados às portas 7777, 7778 e 8443 para garantir que possuem controle de acesso restrito.

output de ufw status verbose

Porta / Protocolo	Ação	Origem	Descrição / Serviço
8443/tcp e 8443/udp	ALLOW IN	Anywhere	Tráfego permitido para a porta 8443 (IPv4 e IPv6) — comumente associada ao Nice DCV ou HTTPS alternativo. TXT + 1
443	ALLOW IN	Anywhere	Tráfego web seguro padrão HTTPS (IPv4 e IPv6).
80/tcp	ALLOW IN	Anywhere	Tráfego web padrão HTTP (IPv4 e IPv6). TXT
22/tcp	ALLOW IN	Anywhere	Acesso remoto via SSH (IPv4 e IPv6). TXT

Resumo

- ✓ 8443/tcp e 8443/udp: ALLOW IN Anywhere (IPv4 e IPv6) — Tráfego permitido para porta 8443 (Nice DCV ou HTTPS alternativo).
- ✓ 443: ALLOW IN Anywhere (IPv4 e IPv6) — Tráfego web seguro padrão HTTPS.
- ✓ 80/tcp: ALLOW IN Anywhere (IPv4 e IPv6) — Tráfego web padrão HTTP.
- ✓ 22/tcp: ALLOW IN Anywhere (IPv4 e IPv6) — Acesso remoto via SSH.

output de ufw status numbered

```
root@ip-10-129-162-185:~# sudo ufw status numbered
Status: active

[ 1] 8443/tcp      ALLOW IN    Anywhere
[ 2] 8443/udp      ALLOW IN    Anywhere
[ 3] 443           ALLOW IN    Anywhere
[ 4] 80/tcp        ALLOW IN    Anywhere
[ 5] 22/tcp        ALLOW IN    Anywhere
[ 6] 8443/tcp (v6)  ALLOW IN    Anywhere (v6)
[ 7] 8443/udp (v6)  ALLOW IN    Anywhere (v6)
[ 8] 443 (v6)       ALLOW IN    Anywhere (v6)
[ 9] 80/tcp (v6)    ALLOW IN    Anywhere (v6)
[10] 22/tcp (v6)    ALLOW IN    Anywhere (v6)
```

- Firewall Ativo: O UFW está ligado ("Status: active"), o que significa que o sistema não está totalmente exposto sem filtragem de pacotes.
- Controle Granular por Portas e Protocolos: Apenas serviços específicos e necessários (portas 22, 80, 443 e 8443) possuem tráfego de entrada permitido, bloqueando todo o resto por padrão.
- Suporte Dual-Stack (IPv4 e IPv6): Há proteção e regras explícitas tanto para o protocolo IPv4 (regras 1 a 5) quanto para o IPv6 (regras 6 a 10), garantindo segurança em ambas as redes.